

EuropeanPay B.V.

Executive Cybersecurity GRC Assessment Report

Confidentiality: Portfolio Simulation — Fictional Organization

Assessment Period: 2026

Assessment Framework: ISO/IEC 27001:2022

Risk Guidance: ISO/IEC 27005

Regulatory Perspectives: GDPR, DORA, NIS2

Prepared for: Executive Management and Board of Directors

1. Executive Summary

EuropeanPay B.V. is a fictional European fintech organization headquartered in Amsterdam, serving approximately 1 million active customers with approximately 500 employees. Its business model depends on continuous availability, confidentiality and integrity of payment services, customer information, financial transaction data and merchant integrations.

EuropeanPay's operating environment includes AWS Frankfurt (**eu-central-1**), Microsoft Azure West Europe (**westeurope**), payment-service integrations, eKYC services, CRM platforms and centralized monitoring.

The assessment was performed as a simulated executive-level GRC assessment using ISO/IEC 27001:2022 as the primary governance framework and ISO/IEC 27005 as supporting risk-management guidance. GDPR, DORA and NIS2 were considered as regulatory perspectives relevant to the organization's operating environment.

The assessment identifies **four priority executive risk themes**:

1. Customer account takeover and identity compromise
2. Exposure of customer and KYC information
3. Payment-service disruption
4. Third-party and ICT supply-chain compromise

These scenarios represent **hypothetical assessment risks and not confirmed security incidents or vulnerabilities**.

The principal management conclusion is that EuropeanPay should prioritize cybersecurity investment around **identity protection, sensitive-data security, operational resilience, third-party risk and formal ISMS development**.

Management should treat cybersecurity as an enterprise risk rather than solely an IT responsibility.

Executive Decision Required

Senior management should approve:

- A prioritized cybersecurity remediation program

- Executive ownership for major cyber risks
- Enhanced third-party risk governance
- Strengthening of identity and privileged-access controls
- Formal ISMS development
- Resilience and incident-response testing
- An indicative cybersecurity/GRC investment envelope of €150,000–€250,000, subject to detailed business-case approval

2. Organization and Business Risk Context

2.1 Business Profile

Category	EuropeanPay B.V.
Industry	FinTech / Digital Payments
Headquarters	Amsterdam, Netherlands
Employees	~500
Active Customers	~1 million
Market	European Union
Operating Model	Digital / API-driven / Multi-cloud

EuropeanPay’s core services include:

- SEPA payments
- Credit card acquiring
- Multi-currency wallets
- Merchant API integrations
- Customer onboarding
- KYC/AML verification
- Transaction monitoring and fraud prevention

The organization’s business model creates a high dependency on information security because disruption or compromise could directly affect customers, merchants, financial transactions and regulatory obligations.

3. Executive Risk Assessment

3.1 Risk Methodology

The assessment uses a qualitative 5×5 risk model.

Risk Score = Likelihood × Impact

Score	Risk Level
-------	------------

1–4	Low
5–9	Medium
10–16	High
17–25	Critical

The methodology is defined specifically for this portfolio assessment and is not an ISO-mandated scoring formula.

Risk is assessed in two states:

Inherent Risk → Treatment → Residual Risk

The final residual scores should be populated from the project's Risk Register after the detailed assessment is completed.

4. Top Executive Risks

RSK-001 — Customer Account Takeover

Risk Event: Unauthorized access to customer accounts through credential compromise, phishing, credential stuffing or weaknesses in authentication.

Business Impact:

- Customer financial loss
- Fraudulent transactions
- Customer trust erosion
- Increased support costs
- Regulatory scrutiny
- Reputational damage

Executive Priority: Critical

Primary Treatment Direction:

- Strong MFA
- Risk-based authentication
- Account-takeover monitoring
- Privileged-access controls
- Credential-compromise detection
- Customer security awareness

Risk Owner: CISO / Security Management

RSK-002 — Customer and KYC Data Exposure

Risk Event: Unauthorized access to customer personal information, KYC/AML documentation, national identification numbers or transaction information.

Business Impact:

- GDPR exposure
- Customer harm
- Regulatory investigation
- Legal costs
- Reputational damage
- Loss of customer confidence

Executive Priority: High

Primary Treatment Direction:

- Least-privilege access
- Data classification
- Encryption
- Access reviews
- Data-loss monitoring
- Retention controls
- Security logging

Risk Owner: CISO / Data Protection Management

RSK-003 — Payment-Service Disruption

Risk Event: Cyberattack, infrastructure failure, cloud outage, DDoS attack or third-party service disruption affects payment processing.

Business Impact:

- Payment failures
- Revenue loss
- Merchant disruption
- Customer dissatisfaction
- Operational losses
- Potential regulatory consequences

Executive Priority: High

Primary Treatment Direction:

- Resilience architecture
- DDoS protection
- Availability monitoring
- Disaster recovery
- Backup and recovery testing
- Third-party resilience assessment

Risk Owner: CTO / IT Management

RSK-004 — Third-Party / ICT Supply-Chain Compromise

Risk Event: Security compromise, outage or control failure involving a critical provider such as AWS, Adyen, Stripe, Sumsub, Salesforce or Datadog.

Business Impact:

- Customer-data exposure
- Payment disruption
- Operational dependency
- Regulatory impact
- Concentration risk
- Difficult recovery or supplier replacement

Executive Priority: High

Primary Treatment Direction:

- Formal supplier risk assessments
- Security requirements in contracts
- Incident notification clauses
- Supplier monitoring
- Concentration-risk assessment
- Exit and contingency planning

Risk Owner: Vendor/Risk Management

5. Risk Treatment and Board Risk Appetite

EuropeanPay should establish a clearly documented risk appetite approved by executive management.

For this simulated assessment, the proposed appetite is:

EuropeanPay should not knowingly accept Critical cybersecurity risks affecting customer funds, critical payment services, sensitive personal information or regulatory obligations without explicit executive approval and documented compensating measures.

Treatment Principle

Risk Position	Management Response
Critical	Immediate executive attention and treatment
High	Formal remediation with defined owner and deadline
Medium	Treatment or monitored acceptance
Low	Monitor and manage through standard controls

Residual risk should only be accepted by an authorized risk owner after treatment options have been evaluated.

6. Current Control Environment

The simulated assessment assumes the existence of baseline controls such as:

- Authentication mechanisms
- Backup processes
- Vendor contracts
- Cloud security controls
- Monitoring
- Security policies
- Access management
- Incident-management capabilities

However, the assessment identifies the need to determine the **effectiveness and maturity** of these controls through evidence.

The key management issue is therefore not simply whether a control exists, but whether it is:

Designed → Implemented → Operating → Tested → Monitored → Improved

7. Priority Control Gaps

7.1 Identity and Access Management

Management should prioritize:

- MFA
- Privileged-access management
- Least privilege
- Periodic access reviews
- Joiner/mover/leaver controls
- Authentication monitoring

Business objective: Reduce account takeover and unauthorized-access risk.

7.2 Third-Party Risk Management

Critical ICT suppliers require a formal lifecycle:

Due Diligence → Contract → Onboarding → Monitoring → Incident Management → Periodic Reassessment → Exit Planning

Critical suppliers should be subject to enhanced oversight.

Business objective: Reduce concentration and supply-chain risk.

7.3 Business Continuity and Disaster Recovery

Critical payment processes should have:

- Recovery Time Objectives
- Recovery Point Objectives
- Documented recovery procedures
- Tested backups
- Disaster-recovery plans
- Recovery exercises

Business objective: Maintain critical financial services during disruption.

7.4 Incident Response

The organization should maintain a documented process:

Detect → Analyze → Contain → Eradicate → Recover → Report → Improve

Incident simulations should test technical, operational, legal, communications and executive responsibilities.

Business objective: Reduce incident impact and improve decision-making under pressure.

8. ISO/IEC 27001:2022 Readiness

The recommended approach is to establish a formal Information Security Management System covering:

- Organizational context
- Interested parties
- ISMS scope
- Risk assessment
- Risk treatment
- Applicable controls
- Statement of Applicability
- Performance measurement
- Internal audit
- Management review
- Continual improvement

Six-Month Illustrative Readiness Program

Period	Executive Milestone
--------	---------------------

Month 1	Confirm ISMS scope, governance and asset inventory
Month 2	Complete risk assessment and treatment plan
Month 3	Implement priority controls
Month 4	Collect evidence and measure control effectiveness
Month 5	Internal audit and corrective actions
Month 6	Management review and Stage 1 readiness

This represents a **portfolio planning scenario**, not a guaranteed certification timeline.

9. DORA Readiness

DORA should be assessed against EuropeanPay's actual regulatory classification and obligations.

Priority areas include:

ICT Risk Management

- ICT asset management
- Risk identification
- Security controls
- Resilience monitoring

ICT Incident Management

- Detection
- Classification
- Escalation
- Reporting
- Lessons learned

Resilience Testing

- Scenario-based exercises
- Recovery testing
- Vulnerability assessments
- Appropriate threat-led testing where applicable

ICT Third-Party Risk

Critical providers should be assessed for:

- Contractual security obligations
- Incident notification
- Service availability
- Concentration risk
- Exit strategies
- Resilience

10. NIS2 Readiness

NIS2 requirements should be mapped according to EuropeanPay's actual applicability and classification.

The GRC program should address:

- Management accountability
- Cybersecurity risk management
- Incident handling
- Business continuity
- Supply-chain security
- Access control
- Vulnerability management
- Security awareness
- Business continuity and disaster recovery

The objective is to demonstrate that cybersecurity risk is governed at management level and supported by measurable controls.

11. GDPR Strategy

EuropeanPay processes sensitive personal information, making privacy governance a major component of enterprise risk management.

Priority areas:

Data Governance

- Data inventory
- Classification
- Minimization
- Retention
- Lawful processing

Security

- Access control
- Encryption
- Monitoring
- Logging
- Data protection

Privacy Operations

- Data-subject rights
- DPIAs where applicable
- Processor/DPA governance
- Retention automation

- Breach management

Executive Objective

Privacy should be integrated into the cybersecurity and GRC program rather than operated as a completely separate compliance function.

12. Strategic Remediation Roadmap

0–30 Days — Immediate Risk Reduction

Management priorities:

- Review critical identities and privileged accounts
- Strengthen MFA
- Validate critical backups
- Confirm ownership of top risks
- Review critical suppliers
- Confirm incident escalation procedures

Expected outcome: Reduce exposure to the most immediate risks.

31–90 Days — Control Strengthening

Management priorities:

- Complete risk assessment
- Implement priority treatments
- Formalize third-party security assessments
- Conduct incident-response exercise
- Test recovery procedures
- Establish cybersecurity KPIs/KRIs

Expected outcome: Improved control maturity and measurable risk reduction.

3–6 Months — GRC Maturity

Management priorities:

- Mature the ISMS
- Complete priority control implementation
- Conduct internal audit
- Perform management review
- Improve regulatory evidence
- Conduct resilience testing

Expected outcome: Improved ISO/IEC 27001 readiness and regulatory preparedness.

6–12 Months — Continuous Assurance

Management priorities:

- Continuous risk monitoring
- Recurring supplier assessments
- Control-effectiveness measurement
- Periodic incident exercises
- Executive cyber-risk reporting
- Continual ISMS improvement

Expected outcome: Sustainable cybersecurity governance.

13. Budget and Resource Requirements

An illustrative portfolio investment envelope of **€150,000–€250,000** is proposed.

Investment	Strategic Purpose
GRC automation	Centralized risk, compliance and evidence management
Security keys / MFA	Identity protection
External audit and assurance	ISO readiness and independent assessment
Security testing	Vulnerability and resilience validation
Third-party risk tooling	Supplier monitoring and assessment
Incident-response exercises	Operational readiness
Security awareness	Human-risk reduction

These are **scenario estimates**, not actual EuropeanPay financial figures.

Investment should be approved using a risk-based business case demonstrating:

Investment → Control Improvement → Risk Reduction → Business Benefit

14. Executive KPIs and KRIs

The board should receive a recurring cybersecurity dashboard.

Recommended metrics:

Metric	Executive Purpose
Critical risks overdue	Shows remediation discipline
High-risk residual exposure	Shows remaining enterprise risk
MFA coverage	Measures identity protection
Privileged accounts reviewed	Measures access governance
Critical suppliers assessed	Measures third-party oversight
Critical incidents	Measures threat exposure
Mean time to detect	Measures detection capability
Mean time to respond	Measures response capability
Backup recovery-test success	Measures resilience
Security-control effectiveness	Measures control maturity
ISO readiness progress	Measures ISMS development
Security training completion	Measures human-risk management

15. Board Decisions Required

The following decisions are recommended for executive approval:

Decision 1 — Cybersecurity Risk Ownership

Approve clear executive ownership for all Critical and High cybersecurity risks.

Decision 2 — Identity Security

Approve accelerated implementation of stronger authentication and privileged-access controls.

Decision 3 — Third-Party Governance

Approve enhanced security assessment and monitoring requirements for critical ICT suppliers.

Decision 4 — Operational Resilience

Approve recurring recovery and incident-response exercises for critical payment services.

Decision 5 — ISMS Development

Approve development of a formal ISO/IEC 27001:2022-aligned ISMS.

Decision 6 — Security Investment

Approve further business-case development for an indicative €150,000–€250,000 security/GRC investment envelope.

16. Executive Management Position

Based on the simulated assessment, EuropeanPay should adopt the following strategic position:

Cybersecurity is an enterprise business risk directly connected to customer trust, payment availability, regulatory exposure and financial resilience. EuropeanPay should therefore manage cybersecurity through an integrated GRC and ISMS program supported by measurable controls, executive accountability and continuous risk monitoring.

The immediate objective should not be certification alone. The priority should be establishing a demonstrably effective security-management system that reduces material business risk.

ISO/IEC 27001:2022 should provide the core management structure, while applicable GDPR, DORA and NIS2 obligations should be incorporated into the organization's broader GRC framework.

17. Final Executive Assessment

EuropeanPay's simulated risk environment warrants **continued executive attention and structured remediation**.

The highest strategic priorities are:

1. **Identity and account security**
2. **Protection of customer and KYC information**
3. **Payment-service resilience**
4. **ICT third-party risk**
5. **Incident response and recovery**
6. **Formal ISMS development**
7. **Continuous executive risk monitoring**

Successful implementation of these priorities would strengthen EuropeanPay's ability to protect customers, maintain payment-service availability, manage third-party dependencies and demonstrate cybersecurity governance.

The next stage of this assessment is to validate these executive conclusions against the detailed **Asset Inventory, Threat & Vulnerability Register, Risk Register, Risk Matrix, Risk Treatment Plan and ISO/IEC 27001 Control Mapping**.

Assessment Disclaimer

EuropeanPay B.V. is a fictional organization created for academic and professional portfolio purposes.

This report is a simulated GRC assessment based on defined scenario assumptions. It does not represent an actual audit, certification assessment, legal opinion, regulatory determination or security assessment of a real company.

Risk ratings, control effectiveness and regulatory applicability must be validated using appropriate evidence before being treated as actual organizational findings.

Primary Framework: ISO/IEC 27001:2022

Risk Guidance: ISO/IEC 27005

Regulatory Perspectives: GDPR, DORA and NIS2

Assessment Approach: Qualitative 5×5 Risk Assessment